



Synthetic No Critical/High

Security Assessment Report

2026-04-09

MODERATE RISK

3 findings identified

0
CRITICAL

0
HIGH

1
MEDIUM

1
LOW

Disclaimer

Assessment Notice

This security assessment was generated using tachi, an automated threat modeling toolkit. The analysis applies STRIDE methodology and AI-specific threat categories to the provided architecture description. Results reflect the automated analysis and should be validated by qualified security professionals.

Scope Limitation

This assessment is limited to the architecture description provided at the time of analysis. It does not cover runtime behavior, implementation-level vulnerabilities, or threats arising from future system changes. The assessment scope is defined in the Assessment Scope section of this report.

Recommendation

This automated assessment should complement, not replace, manual security review by qualified professionals. Organizations should conduct periodic penetration testing, code review, and architecture review in addition to automated threat modeling.

Confidentiality

This document contains sensitive security assessment information. Distribution should be limited to authorized personnel with a legitimate need to review the security posture of the assessed system. Do not share externally without appropriate authorization.

Table of Contents

Disclaimer 2

Table of Contents 3

Risk Methodology 4

Assessment Scope 7

Executive Summary 8

Findings Detail — Severity 10

Risk Methodology

Threat Identification

This assessment uses STRIDE threat modeling combined with AI-specific threat categories to provide comprehensive coverage of both traditional and emerging attack vectors.

STRIDE Categories

Spoofing — Impersonating a user, component, or system to gain unauthorized access.

Tampering — Unauthorized modification of data in transit, at rest, or in processing.

Repudiation — Performing actions without adequate logging or accountability trails.

Information Disclosure — Exposing sensitive data to unauthorized parties through leaks or side channels.

Denial of Service — Degrading or disrupting system availability through resource exhaustion or abuse.

Elevation of Privilege — Gaining higher access rights than authorized through exploitation of trust boundaries.

AI-Specific Categories

Prompt Injection — Manipulating AI model behavior through crafted inputs that override system instructions.

Tool Abuse — Exploiting AI agent tool access to perform unintended or unauthorized operations.

Agent Autonomy — Risks from AI agents acting beyond their intended scope without adequate human oversight.

Data Poisoning — Corrupting training data or context to degrade model accuracy or introduce bias.

Model Theft — Unauthorized extraction or replication of proprietary model weights or behavior.

Probability x Impact Matrix

Each identified threat is assessed for probability of occurrence and potential impact. The intersection determines the overall severity rating used throughout this report.

Impact / Probability	Rare	Unlikely	Possible	Likely	Almost Certain
Critical	H	H	C	C	C
High	M	M	H	C	C
Moderate	L	M	M	H	H
Low	L	L	M	M	H
Negligible	L	L	L	M	M

■ C = Critical ■ H = High ■ M = Medium ■ L = Low

Assessment Overview

Assessment Scope

4 Components

3 Data Flows

3 Trust Boundaries

Components Analyzed

Name	Type	Description
Web UI	External Entity	Public-facing web user interface
API Gateway	Process	Request ingress service
Backend Service	Process	Business logic service
Database	Data Store	Primary relational data store

Data Flows

Source	Destination	Data	Protocol
Web UI	API Gateway	HTTP Request	HTTPS
API Gateway	Backend Service	Validated Request	HTTP
Backend Service	Database	SQL Query	TCP

Trust Boundaries

Zone	Trust Level	Components
Public Edge	Untrusted	Web UI
Application Zone	Semi-Trusted	API Gateway, Backend Service
Data Zone	Trusted	Database

Executive Summary

Severity Distribution

3 findings total



Component Distribution

Component	Findings
API Gateway	1
Backend Service	1
Web UI	1

Detailed Findings

Findings Detail — Severity

Findings Detail — Severity

MEDIUM S-1

Web UI

Minor cosmetic banner spoofing that does not affect user trust

- Apply standard banner style and display consistent branding

LOW S-2

API Gateway

Log verbosity may reveal request parameters to operators

- Redact sensitive parameters from access logs

NOTE S-3

Backend Service

Non-sensitive diagnostic endpoint returns service version

- Restrict diagnostic endpoint to internal network

3 findings | Sorted by risk level (critical first)